

Siber Güvenliğe Giriş

Hafta 2

Siber Saldırı Yaşam Döngüsü (Cyber Kill Chain)

Siber saldırı gerçekleştirilirken izlenen planlı aşamalara Siber Saldırı Yaşam Döngüsü (Cyber Kill Chain) denir.

◦ Bu yaşam döngüsünün aşamaları şunlardır:

- Keşif (Reconnaissance): Saldırganın, hedef sistemde istismar edebileceği güvenlik açıklarını bulmak için gerçekleştirdiği keşif faaliyetleridir.
- Silahlanma (Weaponization): Saldırganın, keşif aşamasında belirlenen güvenlik açıklarına yönelik hangi atak vektörünü kullanacağına karar verdiği aşamadır. Zararlı yazılım veya saldırı araçları bu aşamada geliştirilir.
- İletme (Delivery): Hazırlanan zararlı yazılımın veya saldırı araçlarının hedef sisteme iletilme aşamasıdır. Saldırgan, zararlı yazılım veya saldırı araçlarını e-posta, USB bellek vb. yöntemleri kullanarak hedef sisteme iletir.
- Sömürme (Exploitation): Saldırgan tarafından hedef sisteme iletilen zararlı yazılım kodları çalıştırılarak ve belirlenen atak vektörü kullanılarak zafiyetler sömürülür.
- Yükleme (Installation): Zararlı yazılımın kalıcı bir tehdit hâline gelmesi için hedef sisteme kendisini yükleme aşamasıdır.
- Komuta Kontrol [Command and Control (C2)]: Hedef sisteme yüklenen zararlı yazılımın, uzaktan kontrol edilerek sistemin ele geçirildiği aşamadır.
- Hedefe Yönelik Eylemler (Actions On Objectives): Saldırganın, ele geçirdiği sisteme yönelik verileri elde etme, değiştirme, silme, şifreleme vb. zararlı faaliyetleri gerçekleştirdiği aşamadır.



Sosyal Mühendislik Saldırıları

◦ Sosyal mühendislik, bilişim sistemlerine, bilgisayar ağlarına saldırmak yerine insanları yanıltarak bilgi toplamak, manipüle etmek, duygularını istismar etmek, zafiyetlerinden faydalanmak vb. amacıyla psikolojik ve sosyal tekniklerin kullanıldığı bir saldırı türüdür.

◦ Saldırgan, kurbanlarına kendini yetkili biri gibi tanıtır ve onların güvenini kazanarak kişisel bilgileri, kredi kartı bilgileri gibi önemli bilgileri ele geçirerek haksız kazanç elde etmeye çalışır.

◦ Omuz sörfü, ortalama (phishing) ve kapıdan sızma, yaygın olarak kullanılan sosyal mühendislik saldırılarıdır.

◦ Sosyal mühendislik saldırıları, yetkili bir kurumdan aranıyormuş gibi yapılan bir telefon görüşmesi, sahte web sitelerine yönlendirme veya sahte e-posta şeklinde gerçekleştirilebilir.

◦ Sosyal mühendislik saldırılarına karşı koymanın en etkili yolu, insanların farkındalığını artırmaktır. Kurum çalışanlarına siber güvenlik farkındalığı eğitimleri verilmeli, çalışanlar şüpheli kimlik avı girişimleri ve sosyal mühendislik saldırılarına karşı bilgilendirilmelidir



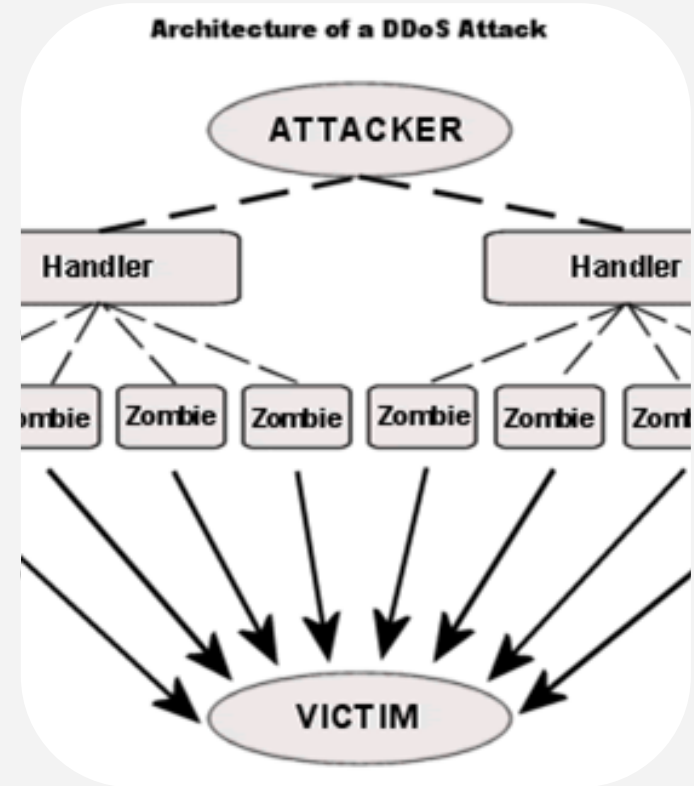
Servis Dışı Bırakma Saldırıları (DoS/DDoS)

◦ Servis Dışı Bırakma Saldırıları (Denial of Service Attack-DoS Attack), internet üzerinde bulunan bir sunucunun geçici veya sürekli servis dışı bırakılarak hizmet veremez hâle getirilmesini hedefleyen ve günümüzde çok sık gerçekleştirilen bir saldırı türüdür.

◦ DoS saldırıları, çok yüksek bant genişliğine sahip trafikler oluşturularak gerçekleştirilir ve hedef sunucu, gereksiz talepler ile aşırı yüklenerek taleplere cevap veremez hâle getirilir. Sunucu bu durumda meşru taleplere de cevap veremeyerek hizmet dışı kalır.

◦ DoS saldırılarının, zararlı yazılımlar aracılığıyla zombi bilgisayarlar hâline getirilerek çok sayıda bilgisayarın kullanılmasıyla gerçekleştirilen hâline (Distributed Denial of Service - Dağıtık Servis Dışı Bırakma) saldırısı denir.

◦ Botnet yazılımları genellikle dağıtılmış servis dışı bırakma saldırılarında (DDoS) kullanılır.



Kaba Kuvvet Saldırıları (Brute Force Attacks)

- Kaba Kuvvet Saldırıları (Brute Force Attacks), bir kullanıcıya ait, olası kullanıcı adı ve şifre kombinasyonlarını deneyerek bulup ele geçirmeye yönelik saldırı türüdür.
- Bu saldırı genellikle basit, zayıf şifre ve parolaları hedef alır.
- Kaba kuvvet saldırılarına karşı alınabilecek önlemlerden bazıları şunlardır:
 - Güçlü parola ve şifre kullanmak: En az 12 karakter, büyük-küçük harf, sayı ve özel karakterden oluşacak şekilde şifre ve parola belirlemek. Ağ güvenlik planında da en az 8 karakter olmak üzere büyük, küçük harf, sembol ve rakamlardan oluşan, düzenli olarak değiştirilen parolalar tercih edilmesi belirtilmiştir.
 - İki faktörlü kimlik doğrulama kullanmak.
 - Belirli bir sayıdan fazla başarısız deneme sonucunda hesaba erişimi otomatik olarak durdurmak.
 - Belirli bir sayıdan fazla başarısız deneme yapılan kaynak IP adresini filtrelemek.



Ortadaki Adam Saldırısı (Man In The Middle Attack)

- Ortadaki Adam Saldırısı (Man In The Middle Attack), aynı ağ içinde haberleşen iki bilgisayarın arasına girilerek ağ trafiğinin saldırgan bilgisayar üzerinden gerçekleştirildiği saldırı türüdür.
- Bu saldırı türünde saldırgan, iki bilgisayar arasındaki ağ trafiğini dinleyebilir.
- Gerekli güvenlik önlemleri alınmadığında çoğu zaman saldırıya uğrayan bilgisayarlar, saldırıya maruz kaldıklarını anlayamaz.
- Sahte erişim noktası, DHCP sahtekârlığı, DNS sahtekârlığı ve ARP sahtekârlığı en yaygın ortadaki adam saldırılarıdır. Kaynaklarda ARP önbellek zehirlenmesi atağı uygulaması örneği verilmiş olup, bu saldırı sonucunda ağ geçidinin MAC adresi saldırgan bilgisayarın MAC adresi ile değiştirilerek saldırganın hedef bilgisayarın ağ trafiğini dinlemesi sağlanır.



SQL Enjeksiyon Saldırıları

- SQL Enjeksiyon Saldırıları (SQL Injection Attacks), web uygulamalarındaki güvenlik açıkları kullanılarak gerçekleştirilen bir saldırı türüdür.
- Saldırgan, SQL sorgularına müdahale ederek hedef veri tabanındaki SQL kodlarını değiştirebilir.
- Bu tür saldırılar sonucunda saldırgan, veri tabanı yöneticisinin şifre ve parolalarını ele geçirebilir, veri tabanındaki verilere erişip onları çalabilir, yok edebilir ve değiştirebilir.
- Yazılımlarda XSS ve SQL enjeksiyon saldırılarına uygun zafiyetlerin bulunması, arka kapı oluşturulmasına yol açabilir.



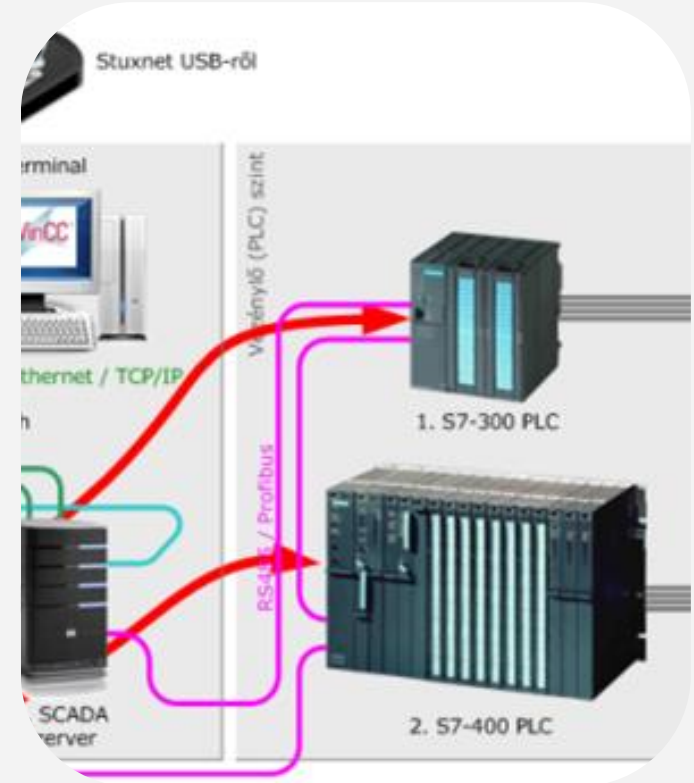
Sıfırncı G n Saldırıları (Zero Day Attacks)

- Sıfırncı G n Saldırıları (Zero Day Attacks), g venlik a ığı bulunan yazılımların, sistemlerin, hen z a ıklarının  reticisi tarafından fark edilmediđi ve g venlik a ığının ortadan kaldırılmadıđı durumlar, sıfırncı g n a ığı olarak tanımlanır.
- Bu a ıklıktan yararlanılarak ger ekleřtirilen siber saldırılara ise sıfırncı g n saldırısı denir.
- Sıfırncı g n saldırısına karřı alınabilecek  nlem, g venlik a ığı fark edildiđinde  ok hızlı bir řekilde yamalama iřleminin ger ekleřtirilmesidir.
- Ađ saldırılarına neden olan etkenlerden biri de sıfır g n (zero day) a ıklarıdır.



Gelişmiş Sürekli Tehdit (Advanced Persistent Threat – APT)

- Gelişmiş Sürekli Tehdit (Advanced Persistent Threat – APT), saldırganların bir ağa gizlice sızarak ve uzun bir süre fark edilmeden kalarak verilerin ele geçirilmesini hedefleyen, karmaşık, sofistike ve sürekli saldırılardır.
- APT saldırıları, geleneksel siber saldırılardan farklıdır.
- Genellikle birbirine düşman devletler veya organizasyonlar tarafından gizlice yürütülür.
- Çok yüksek düzeyde uzmanlık ve kaynak gerektirir.
- Stuxnet, APT saldırılarına bir örnektir.



Zararlı Yazılım Saldırıları ve Önlemler

◦ Zararlı Yazılım Saldırıları (Malware Attack), kötü niyetli amaçlar için geliştirilen zararlı yazılımların, bilgisayar ağlarına, bilgisayarlara bulaştırılması şeklinde gerçekleştirilen saldırı türüdür. Ağ saldırılarına neden olan etkenlerden biri de zararlı yazılımlardır.

◦ Siber güvenlik uzmanları, zararlı yazılımlara karşı koymakla sorumludur.

◦ Zararlı yazılım saldırılarına karşı alınabilecek önlemlerden bazıları şunlardır:

- İşletim sisteminin lisanslı ve güncel olması.
 - Güncel bir virüs tarama programının kullanılması.
 - Güvenilir olmayan web sitelerinden dosya indirilmemesi.
 - Kaynağı bilinmeyen e-posta ve eklentilerinin açılmaması.
 - Taşınabilir ve USB belleklerin kullanılmadan önce virüs taramasından geçirilmesi.
- Ağdaki bilgisayarlara virüsten koruma, casus yazılım önleme uygulamaları yüklenmelidir.



Fiziksel Güvenlik

- Fiziksel güvenlik, bilişim sistemleri, ağlar, donanımlar ve verilerin bulunduğu fiziksel ortamların, fiziksel tehditlere ve saldırılara karşı korunması için alınan önlemleri ifade eder.
 - Fiziksel güvenlik önlemleri; bilişim altyapısının, ağ cihazlarının, ağ kablolarının ve bilgisayarların hırsızlık, sabotaj, doğal afetler gibi fiziksel tehditlere karşı korunmasını sağlar.
 - Bilişim sistemlerinin fiziksel güvenliğini sağlamak için alınacak tedbirlerden bazıları şunlardır:
 - Bina girişinde ve bina içinde fiziksel her ortama erişim için yetkilendirme yapılmalıdır. Bu yetkilendirme kartlı sistemler veya biyometrik verilerle sağlanabilir.
 - Sunucu, ağ cihazları gibi bilişim altyapısıyla ilgili cihazlar bir sistem odasında bulunmalı, fiziksel olarak kilitli tutulmalı ve yetkisiz erişim engellenmelidir.
 - Güvenlik kamerası sistemleri ile fiziksel güvenlik kontrol edilmelidir.
 - Yangın söndürme sistemleri kullanılarak olası bir yangında bilişim altyapısının zarar görmemesi sağlanmalıdır.
 - Switch cihazı fiziksel olarak gizli bir bölmede saklanabilir.

Ağ Güvenliği Temelleri ve Önemi

- Ağ (Network), iki veya daha fazla bilgisayarın (nesnenin) kablolu veya kablosuz iletişim araçları üzerinden yazılım ve donanım bileşenleriyle birbirine bağlandığı, bilgi ve sistem kaynaklarının kullanıcılar arasında paylaşıldığı bir haberleşme sistemidir.
 - Kıymetli verilerin ağlar üzerinden aktarılması saldırganları cezbetmektedir. Bu zararların en aza indirilmesi ağ güvenliği kavramı ile mümkündür.
 - Ağ güvenliği; ağdaki bilgisayarların güvenliğini sağlamak, ağ trafiğini korumak, ağ saldırılarını algılamak ve önlemek, yetkisiz erişimleri engellemek, ağ trafiğini kontrol altına almak için gerekli olan teknikleri, araçları ve güvenlik planlamalarını kapsayan bir kavramdır.
 - Bilgisayar ağlarına yapılan saldırılar hassas verilerin yetkisiz kişiler tarafından okunmasına, değiştirilmesine veya silinmesine neden olmaktadır. Bu durum ciddi miktarda para, zaman, prestij ve hassas veri kaybı yaratır.
 - Bu nedenle bilgisayar ağlarının, bilgi güvenliğinin üç temel unsuru olan gizlilik, bütünlük ve erişilebilirlik kapsamında korunması büyük önem taşımaktadır.
 - Ağları istismar etmek isteyen bilgisayar korsanlarının varlığı her geçen gün artmaktadır. Bu yüzden bir kurum ağının yetkisiz erişim, kötüye kullanım veya imha durumundan korunması için ağ güvenlik planı son derece önemlidir.

Ağ Güvenlik Planı

- Ağ güvenlik planı, bilgisayar ağını yetkisiz kullanıcılardan korumak için kullanılan teknikleri tanımlayan ve bir sistemin güvenliğini tehlikeye atabilecek olaylara karşı koruma sağlayan bir stratejidir.
 - Bu plan, güvenli bir bilgi işlem ve ağ ortamı sağlamak için uyulması gereken yönergelerden oluşur.
 - Ağ güvenlik planı, bilgi güvenliği unsurlarının korunmasını hedefler.
 - Bilgisayar ağındaki tüm kullanıcıların gerekli eğitimler ile güvenlik bilincine sahip olması, ağ güvenlik planının önemli bir bileşenidir.
 - Bir kurumun ağ güvenlik planının olmaması durumunda itibar kaybı yaşaması kaçınılmazdır.
 - Ayrıca yeni yasal düzenlemeler ve ağ topolojisindeki önemli değişiklikler, ağ güvenlik planının gözden geçirilip güncellenmesini gerektirir.
 - Bir ağın güvenliğini sağlamak için yönlendiriciler, güvenlik duvarları, izinsiz giriş algılama / önleme sistemleri ve son kullanıcı cihazı güvenlik yazılımları gibi bileşenlerin kombinasyonuna ihtiyaç duyulur.

Ağ Güvenlik Planı Adımları: Varlık Tanımlama ve Tehdit Değerlendirmesi

- Ağ güvenlik planının oluşturulması için gereken adımlar:
 - Güvence altına almak istediğiniz ağ varlıklarını tanımlayınız. Kurum çalışanlarının bilgisayarları, sunucular, depolanan veriler, gizli ve hassas veriler, ağ iletim ortamından aktarılan veriler, anahtarlar (switch) ve yönlendiriciler (router) ağ varlıklarına örnek olarak verilebilir.
 - Tehdit değerlendirmesini gerçekleştiriniz.
 - Ağdaki güvenlik açıkları tanımlanır ve sınıflandırılır.
 - Kritik sistem ve cihazlarda kullanılan zayıf parola veya varsayılan parola gibi istismar edilebilecek zafiyetler belirlenir.
 - Uygulama, dosya ve veri tabanı sunucularındaki ağ güvenlik açıkları bulunur.
 - Kritik sistemlerde şifreleme ayarları kontrol edilir.
 - Sızma testi gerçekleştirilerek sistemdeki güvenlik açıkları tespit edilir.
 - Tespit edilen bulguların önem derecesine göre düzeltme önerileri belirtilir.

Ağ Güvenlik Planı Adımları: BT ve Ağ Güvenliği Politikası Geliştirme

- Ağ güvenlik planının oluşturulması için gereken adımlar:
 - BT ve ağ güvenliği politikası geliştiriniz.
 - Ağa giren ve çıkan trafiği filtrelemek için bir güvenlik duvarı oluşturulur.
 - Gizli ve hassas bilgilere sahip sistemlere yalnızca kimliği doğrulanmış kullanıcılar erişebilmelidir. Kimlik doğrulaması kullanılmalıdır.
 - En az 8 karakter olmak üzere büyük, küçük harf, sembol ve rakamlardan oluşan, düzenli olarak değiştirilen parolalar tercih edilmelidir.
 - Tüm hassas veriler şifrelenmelidir.
 - Uzak kullanıcılar VPN (Sanal Özel Ağ) ile güvenli bağlantılar kurmalıdır.
 - Ağdaki bilgisayarlara virüsten koruma, casus yazılım önleme uygulamaları yüklenmelidir.
 - Alt ağlar oluşturulabilir ve Sanal Yerel Alan Ağları (VLAN) kullanılabilir.

Ağ Güvenlik Planı Adımları: Güvenli Kablosuz Ağ ve Güvenlik Bilinci

- Ağ güvenlik planının oluşturulması için gereken adımlar:
 - Güvenli kablosuz ağları kullanınız.
 - Kablosuz ağ adı (SSID) değiştirilmeli veya gizlenmelidir.
 - Kablosuz erişim noktaları yönetici panellerinin varsayılan parolaları değiştirilmelidir.
 - Kimlik doğrulaması kullanılmalıdır.
 - Ortak kablosuz ağlar kullanılırken hassas veriler paylaşılmamalıdır.
 - Güvenlik bilinci oluşturunuz.
 - Kurum çalışanlarına siber güvenlik farkındalığı eğitimleri verilmelidir.
 - Çalışanlar, şüpheli kimlik avı girişimleri ve sosyal mühendislik saldırılarına karşı bilgilendirilmelidir.
 - Yaygın ağ güvenlik açıkları ve bunların nasıl önleneceği konusunda eğitim oturumları düzenlenmelidir.
 - Kurum çalışanlarının hazırlık düzeyini ölçmek için sahte ağ saldırıları oluşturulabilir.



- Ağ güvenlik planının oluşturulması için gereken adımlar:
 - Olay müdahalesi tanımlayınız. Olay müdahalesi, bir güvenlik ihlali veya siber saldırı sonrasında hasarı sınırlamayı, kurtarma süresini ve maliyeti azaltmayı hedeflemektedir.
 - Güvenlik kontrollerini standartlara göre gerçekleştiriniz. Güvenli ağlar oluşturmak için ISO 27001 Bilgi Güvenliği Yönetim Sistemi gibi standartlara uyulmalıdır.
 - Bir güvenlik firmasından danışmanlık hizmeti alınız. Bu firmalar, kurumun ağ güvenlik planını uygulamasına yardımcı olur ve siber güvenlik sorunlarının çözümünde ilgili kuruma destek olur. Örnek olayda belirtilen kurum, başarılı bir siber güvenlik firmasından danışmanlık hizmeti alarak benzer saldırıları engellemenin yöntemini öğrenmelidir.



- Ağ güvenlik planının oluşturulması için gereken adımlar:
 - Güvenliğin sürekliliğini sağlayınız. Güvenlik politikaları belirli aralıklarla gözden geçirilmeli ve ağ güvenlik planının genel bir incelemesi yapılmalıdır.
- Ağ saldırılarına neden olan etkenlerden bazıları şunlardır:
 - Ağ cihazlarının eksik veya yanlış yapılandırılan konfigürasyonları.
 - Ağ cihazlarının varsayılan olarak bırakılan ayarları.
 - Ağ ve son kullanıcı cihazlarının zafiyetleri.
 - TCP/IP protokol (TCP, ARP, ICMP, DHCP, DNS vb.) zafiyetleri.
 - Zamanında yapılmayan işletim sistemi ve firmware güncellemeleri.
 - Yazılım açıkları, Sıfır gün (zero day) açıkları.
 - P2P dosya paylaşım ağ bağlantıları, Şifreleme kullanılmayan veri aktarımları.
 - Halka açık kablosuz ağlar, Zararlı yazılımlar.
 - Son kullanıcı zafiyetleri, Ağ ve sistem yöneticilerinin ihmali.

Ağ Trafiğinin Kontrol Altına Alınması

- Gelen ve giden ağ trafiğinin kontrol altına alınması, ağ güvenliğinin sağlanması için güvenlik duvarı (firewall) kullanılması oldukça önemlidir.
- Güvenlik duvarı, haricî ağdan gelen ve istenmeyen trafiği engeller.
- Bazen güvenlik duvarından geçen trafikte istenmeyen paketler olabilir.
- Bu nedenle güvenlik duvarları saldırı tespit ve önleme sistemleri (IDS/IPS) ile desteklenmelidir.



Saldırı Tespit Sistemi (IDS)

IDS; ağdaki tüm trafiği sürekli dinler, veri paketine bakar, saldırı olarak tanımlanan işlemleri tespit ettiği an uyarı sistemi aracılığıyla sistem yöneticisine veya SIEM sistemine bilgi (alarm) verir.

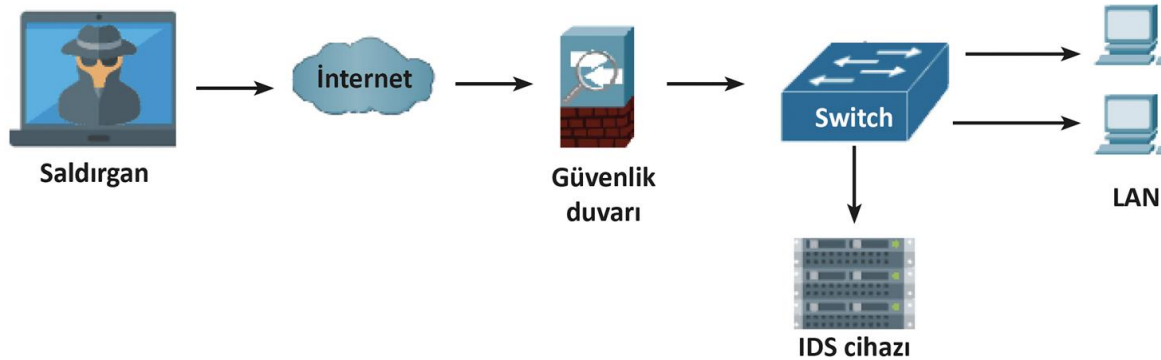
7 Best Intrusion Detection Software Tools

		Free Trial?	Top Features			Bottom Line
SolarWinds Security Event Manager		30-Day	IDS logs collation	Risk assessment reports	Automated asset discovery	This fantastic IDS tool offers comprehensive IT security solutions, with automated asset discovery and versatile reporting utilities.
Kismet		Free Tool	Basic features	Various plugins available	Export to PDF	This open source IDS tool can be extended with a range of plugins.
Zeek		Free Tool	Track DNS, HTTP, and FTP activity	Customizable policy scripts	Monitor SNMP traffic	This program allows you to track DNS, HTTP, and FTP activity and lets you customize policy scripts.
Open DLP		Free Tool	Data loss prevention focus	Identifies at-rest data across thousands of systems	Agents or agentless	Free IDS tool focuses on data loss prevention and is capable of agent and agentless scanning.
Sagan		Free Tool	Multi-threaded architecture	Compatible with rule management software	Snort-like design	This program uses multi-threaded architecture and is compatible with rule management software.
Suricata		Free Tool	Integrates with other databases	Supports standard output and input formats	Detects complex threats	This tool is capable of identifying complex and advanced threats, and can be integrated with other databases, like Splunk and Kibana.
Security Onion		Free Tool	Suite of tools	NIDS/HIDS hybrid	Traffic pattern insight	This is a HIDS/NIDS hybrid suite of security tools that can give you detailed insight into traffic patterns and device status information.



Saldırı Tespit Sistemi (IDS)

SIEM sistemine gelen alarmlar bazen hatalı olabilir. SIEM (Security Information and Event Management) bu alarmları analiz edip hangilerinin hatalı, hangilerinin hatasız olduğunu belirlemeye çalışır. Sistem yöneticileri de uyarılara göre gerekli önlemleri alarak saldırıları engelleyebilir. IDS, dinlediği trafiğin kaydını tutabilir ve rapor oluşturabilir. IDS cihazı genellikle switch (anahtar) cihazına bağlanır. IDS switch cihazına bağlanırken SPAN portunu kullanır.



Saldırı Tespit Sistemi (IDS)

SIEM, Güvenlik Bilgisi ve Olay Yönetimi Sistemi olarak tanımlanır. SIEM, ağ saldırılarını daha hızlı bir şekilde tespit edebilmek için ağdaki güvenlik cihazlarında tutulan bütün logları toplayan, analiz eden ve gerektiğinde uyarı veren bir yazılımdır.

IDS araçları, imza ve davranış tabanlı olmak üzere iki tür çalışma şekline sahiptir.

İmza Tabanlı IDS: Dinlediği ağ trafiğini kendi veri tabanındaki saldırılara ait imzaları (kural listeleri) sorgulayarak karşılaştırır. Bunun sonucunda alarm verip vermeyeceğini kararlaştırır. İmzaların bulunduğu veri tabanı sürekli güncel tutulmalıdır.

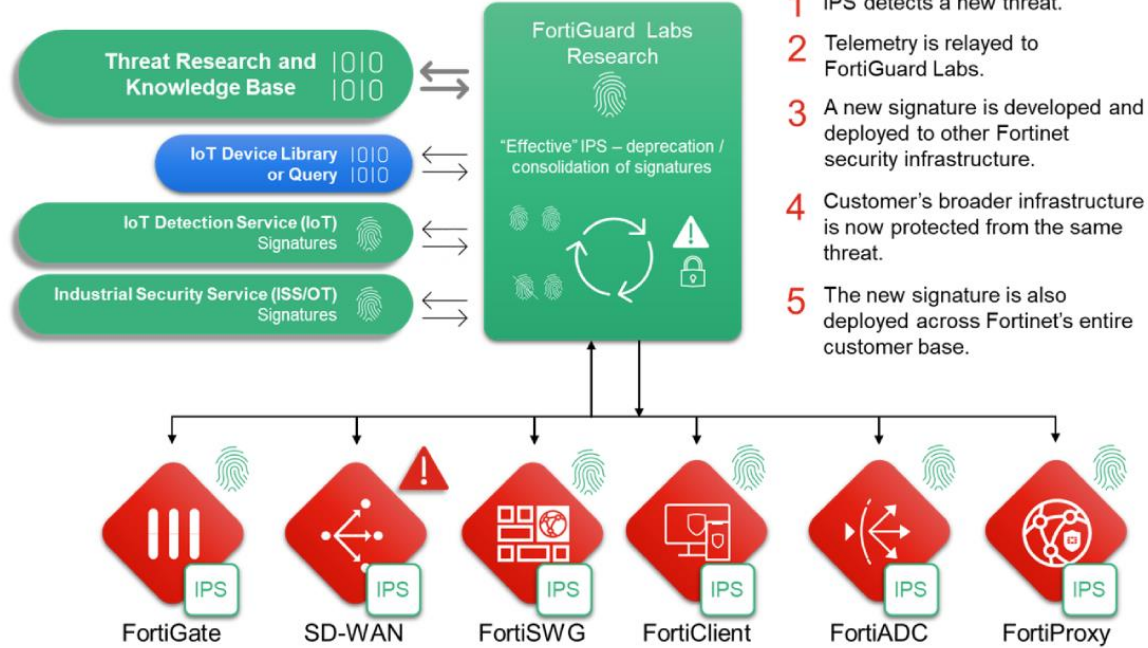
Davranış Tabanlı IDS: Normal davranışa sahip trafiği analiz ederek dinlediği ağ trafiği ile karşılaştırır. Dinlenen trafik, normal davranışa sahip trafiğe benzemiyorsa anomali olarak sınıflandırılır.



Saldırı Önleme Sistemi (IPS)

<https://www.cisco.com/c/en/us/products/security/ngips/index.html#~features>

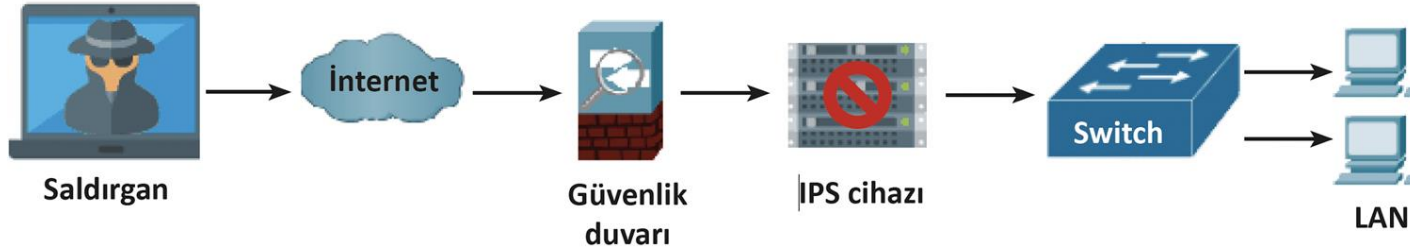
<https://www.fortinet.com/support/support-services/fortiguard-security-subscriptions/intrusion-prevention>



Saldırı Önleme Sistemi (IPS)

IPS, üzerinden geçen trafiği bölmeden çalışır ve trafiğe ait tüm paketleri derinlemesine inceler. Paketlerin hangisinin saldırı niteliği taşıdığını, hangisinin zararsız olduğunu tespit ederek ağı koruma altına alır. IPS, saldırıları etkili olmadan önler. Ayrıca daha önceden tespit edilmesi mümkün olmayan saldırıları da algılar.

IPS cihazı genellikle güvenlik duvarının arkasına bağlanır. IPS, paketleri dâhilî ağa ileten iletişim yolunun içindedir

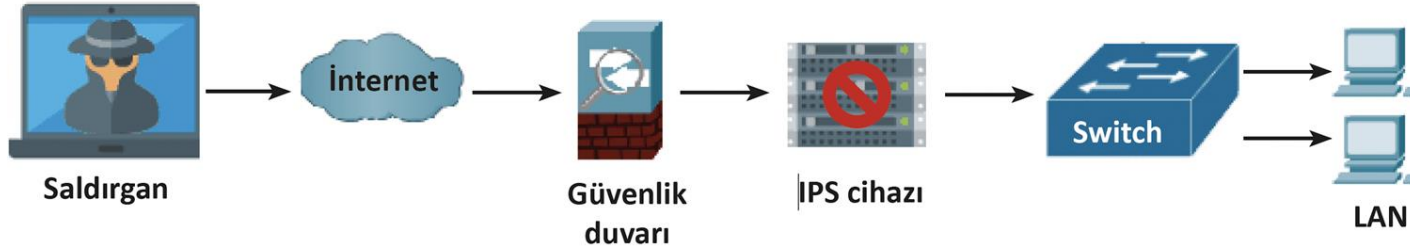


Saldırı Önleme Sistemi (IPS)

IPS araçları, imza ve davranış tabanlı olmak üzere iki tür çalışma şekline sahiptir.

İmza Tabanlı IPS: Ağ trafiğini kendi veri tabanındaki saldırılara ait imzalar (kural listeleri) ile karşılaştırır. İmza ile eşleşen veri paketleri tespit edildiğinde trafik akışı engellenir.

Davranış Tabanlı IPS: Ağdan farklı zamanlarda alınan trafik örnekleri, ağın normal davranışına göre istatistiksel sapmalar oluşturursa anomali olarak sınıflandırılır. Bu çalışma şeklinde saldırı içermeyen trafikler de engellenebilir.



NOT

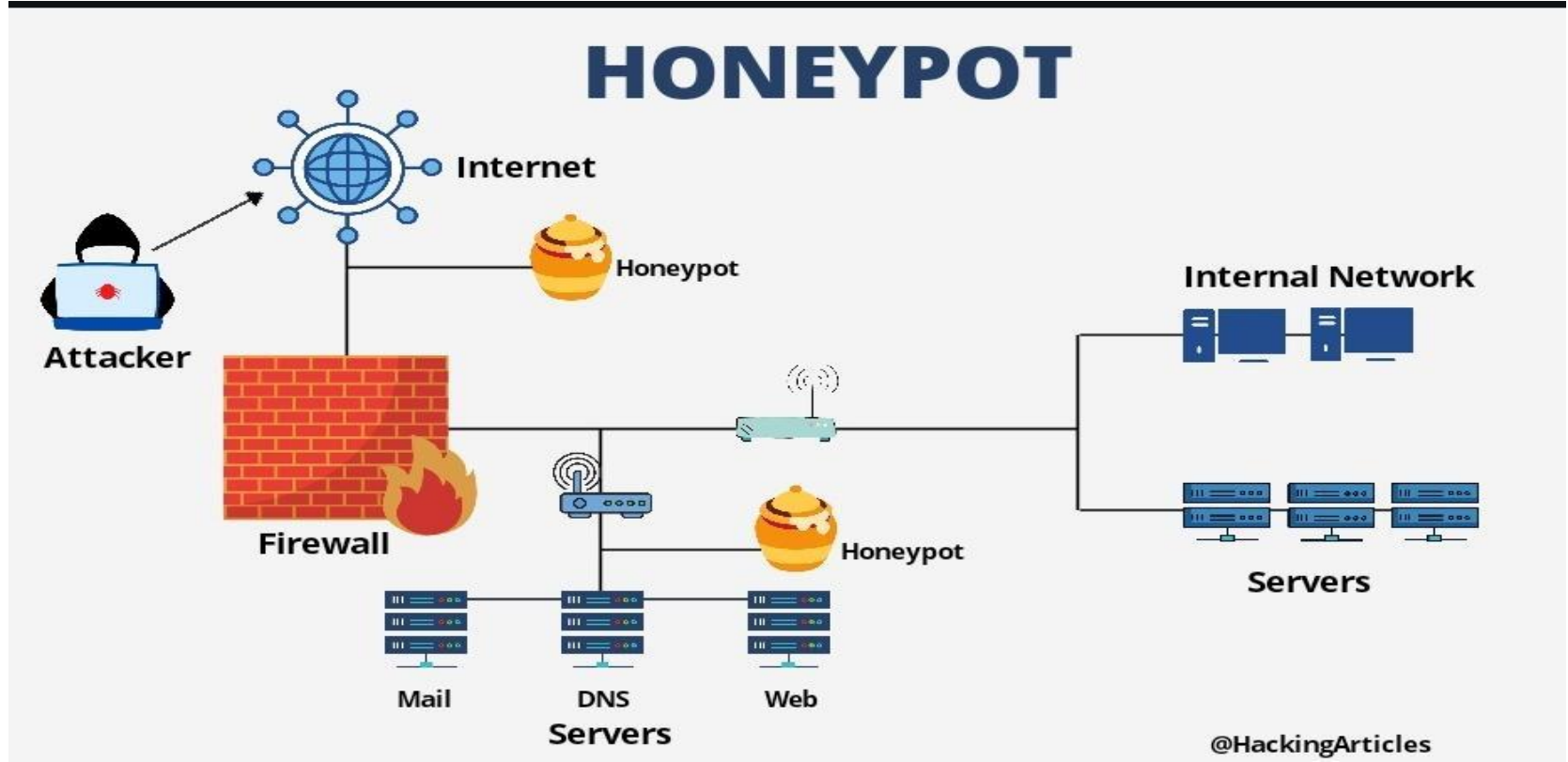
Saldırı tespit ve önleme sistemleri, yazılımsal veya donanımsal olarak üretilen güvenlik sistemleridir. IPS ve IDS cihazları bir arada kullanıldığında IDPS (Intrusion Detection and Prevention Systems) olarak tanımlanır. Gelişmiş sistemlerde IPS ve IDS bütünleşik olarak kullanılır.

Bal Kupu (Honeypot)

Bal kupu; saldırgan hakkında bilgi toplamaya yarayan tuzak sunucudur. Öngörülebilir kötü niyetli davranışları sergileyerek saldırganın dikkatini çeker. Bal kupunde saldırganın davranışı yakalanır, günlüğe kaydedilir ve analiz edilir. Bunun sonucunda ağ yöneticisi daha fazla bilgi elde edebilir, daha iyi bir savunma gerçekleştirebilir. Honeypot; saldırıları tespit etmek, yavaşlatmak, gerçek sistemi gizlemek için kullanılan bir teknolojidir.

<https://github.com/telekom-security/tpotce>

Bal Kupu (Honeypot)



Ağ Trafiğinin Kontrol Altına Alınması

Gelen ve giden ağ trafiğinin kontrol altına alınması, ağ güvenliğinin sağlanması için güvenlik duvarı (**firewall**) kullanılması oldukça önemlidir. Güvenlik duvarı, haricî ağdan gelen ve istenmeyen trafiği engeller. Bazen güvenlik duvarından geçen trafikte istenmeyen paketler olabilir. Bu nedenle güvenlik duvarları saldırı tespit ve önleme sistemleri ile desteklenmelidir.



Güvenlik Duvarı (Firewall)

Güvenlik duvarı genellikle ağın ve bilgisayarların yetkisiz erişimlerden korunmasını sağlayan yazılım veya donanım olarak tanımlanmaktadır. Yapılarına göre güvenlik duvarı türleri aşağıda verilmiştir.

Yazılımsal Güvenlik Duvarı: Daha çok ev ve küçük ofislerde internet güvenliğini sağlamak, son kullanıcı cihazlarını zararlı yazılımlardan korumak amacı ile kullanılmaktadır. Windows için Defender, Linux için IPTables yazılımsal güvenlik duvarı örnek olarak verilebilir.

Donanımsal Güvenlik Duvarı: Ağı korumak için ek güvenlik sunan cihazlardır. Ayrı bellek ve işlemci kullanan bu cihazlar, yüksek bant genişliğinde çalışabilir. Daha çok kurumsal ağlarda tercih edilir.



Güvenlik Duvarı (Firewall)

Paket filtrelemeli güvenlik duvarları, router (yönlendirici) ile entegre çalışır. Bu tür güvenlik duvarlarında Erişim Kontrol Listesi (ACL-Access Control List) kullanılır. ACL kullanılarak kurallar tanımlanır. Güvenlik duvarından geçen her bir pakete bakılır. Ağ trafiği önceden tanımlanmış kurallara uygunsa paketin geçişine izin verilir. Aksi hâlde paket yok edilir. Paket filtreleme, güvenlik duvarının her bir portunda dışarıya çıkış veya içeriye giriş yönünde uygulanabilir.



Demo

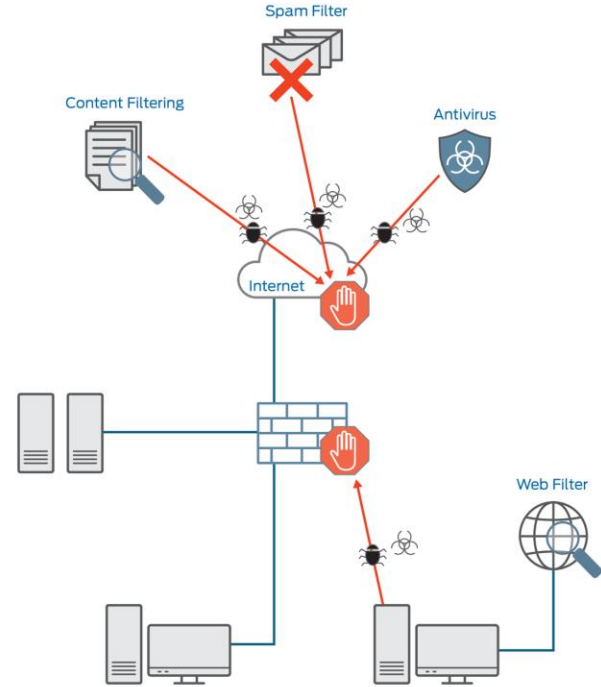
<https://fortigate.fortidemo.com/>

Kullanıcı adı: demo

Parola: demo

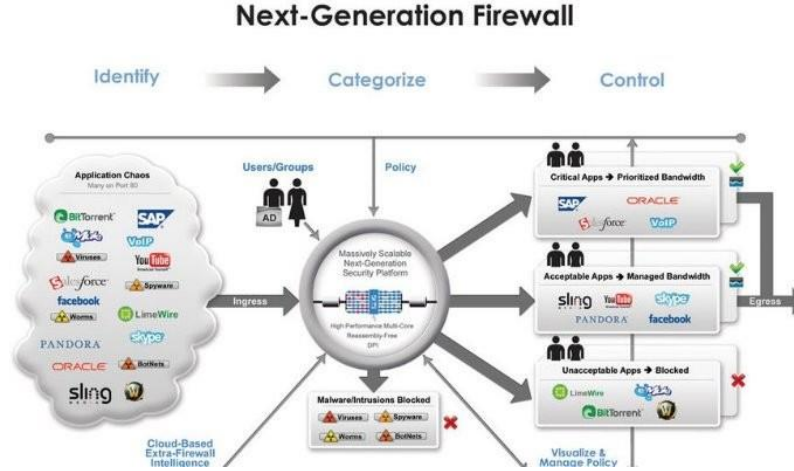
Birleşik Tehdit Yönetimi (UTM)

UTM (Unified Threat Management), her türlü tehdidi tek cihazla engelleyebilen birleşik güvenlik sistemidir. UTM cihazları temelde güvenlik duvarı olarak çalışır. Gelen ve giden ağ trafiğini kontrol ederek istenmeyen durumları engeller. Bu cihazlar ayrıca IPS/IDS, web filtreleme, içerik filtreleme, spam e-posta filtreleme, casus yazılım önleme, anti-virüs, VPN ve log tutma hizmetlerini de gerçekleştirir.



Yeni Nesil Güvenlik Duvarı (NGFW)

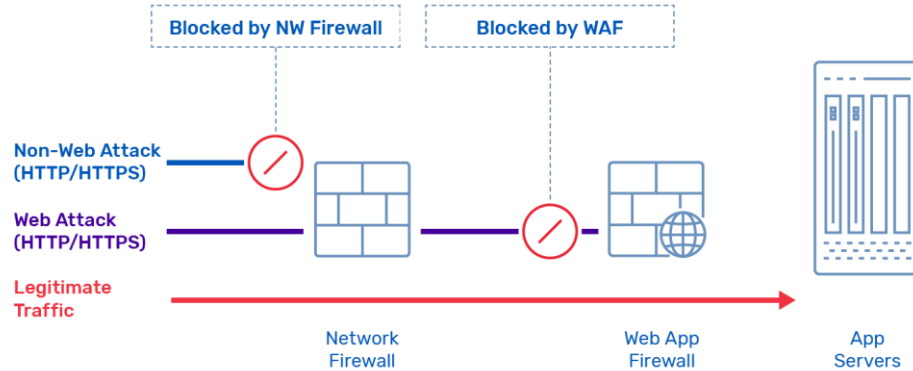
NGFW (Next Generation Firewall); DLP, IPS, IDS, içerik filtreleme gibi güvenlik sistemlerini tek bir yapıda toplayan kapsamlı ve tümleşik bir cihazdır. Bu cihazların en önemli özelliği kimlik denetimidir. Kimlik denetimi, sistemdeki kullanıcının IP adresi değişse de aynı yetkilerle ağa ulaşabilmesini sağlar. Bunlar, port üzerinde çalışan uygulama ve cihazların kontrolünü yapar. Her türlü ağ protokolünü kontrol ederek güvenli bir katman oluşmasına yardımcı olur. Bu sayede karmaşık saldırılar tespit edilip engellenebilir.



Web Uygulama Güvenlik Duvarı (WAF)

WAF (Web Application Firewall); karmaşılaşan web trafiği üzerinde detaylı inceleme yaparak anormallikleri filtreleyen ve gelen isteklerden saldırgan amaçlı olanları engellemeye çalışan bir araçtır. WAF, OSI modelinin yedinci katmanında çalışır. HTTP, HTTPS, SOAP, XML, RPC gibi protokoller üzerinde detaylı paket incelemesi yaparak zararlı istekleri bloklar.

Web Application Firewall vs Network Firewall



Yetkisiz Erişimin Engellenmesi

Yetkisiz erişimin engellenmesi için OSI modelinin veri bağı ve ağ katmanı düzeyinde gerekli teknikler uygulanmalıdır. Yerel alan ağına bağlanan saldırgan o ağın tüm imkânlarından yararlanabilir. Kablosuz ağların yaygınlaşması, yetkisiz erişimlerin artmasına neden olmaktadır.



Yetkisiz Erişimin Engellenmesi

Yetkisiz erişimi engellemek amacıyla veri bağı katmanı seviyesinde alınabilecek önlemler şunlardır:

- Switch cihazına bağlı bilgisayarları mantıksal olarak gruplandırmak, gruplar arasındaki trafiği sınırlandırmak ve güvenliğini artırmak için VLAN oluşturulabilir.
- Switch üzerinde port security yapılandırması gerçekleştirilebilir.
- Switch üzerinde PortFast, Root guard, BPDU guard aktif edilerek STP saldırıları azaltılabilir.
- Switch cihazının sadece gerekli olan portları trunk yapılandırılarak VLAN hopping atakları azaltılabilir.

Yetkisiz Erişimin Engellenmesi

- Switch cihazının her portu için statik MAC adresler ayarlanabilir.
- Switch cihazının sınırlı sayıda MAC adresini otomatik öğrenmesi ayarlanabilir.
- Kullanılmayan tüm switch portları kapatılıp kullanılmayan bir VLAN'a taşınabilir.
- Switch cihazı fiziksel olarak gizli bir bölmede saklanabilir.
- Kablosuz ağlarda şifreleme ve kimlik doğrulama kullanılabilir.
- Kablosuz ağlarda SSID gizlenebilir.
- Kablosuz erişim noktasının varsayılan parola ve kullanıcı adları değiştirilebilir.

Yetkisiz Erişimin Engellenmesi

Yetkisiz erişimi engellemek amacıyla ağ katmanı seviyesinde alınabilecek önlemler şunlardır:

- Donanımsal güvenlik duvarı kullanılabilir.
- Erişim kontrol listeleri kullanılabilir.
- Saldırı tespit ve önleme sistemleri kullanılabilir.
- Sanal Özel Ağ (VPN) kullanılabilir.

Yazılım Güvenliği İlkeleri

- Yazılım güvenliği, saldırılara maruz kaldığında dahi işlevlerini doğru bir şekilde yerine getirmeye devam edebilmesi için yazılımın geliştirilmesidir. Bu, güvenlik faktörleri göz önünde bulundurularak yazılımın tasarlanması, geliştirilmesi ve test edilmesi sürecini içerir.
- Temel amaç, hatasız ve gerçek dünya kullanımında tüm bilgi güvenliği saldırılarına karşı daha dayanıklı yazılımlar üretmektir.
- Yazılım güvenliği ilkeleri, güvenli yazılım geliştirme yaşam döngüsünde dikkat edilmesi gereken temel güvenlik unsurlarını içerir. Bu ilkeler şunlardır:
 - Gerek Duyulan En Az Yetkiyi Vermek: Kullanıcılara veya yazılım bileşenlerine, sadece gerekli minimum yetkilerin verilmesi.
 - Tüm Erişimleri Denetlemek: Kullanıcıların ve bileşenlerin erişimlerini izlemek ve denetlemek.
 - Yetkileri Ayırmak: Farklı kullanıcılar veya bileşenler arasında yetkileri ayırıştırmak.
 - Varsayılan Değerleri Güvenli Hâle Getirmek: Yazılımın varsayılan değerlerini güvenli bir biçimde tanımlamak.
 - Ortak Erişilen Kaynaklara Farklı Kaynaklardan Erişmek: Ortak kaynaklara her biri için ayrı izinler ve sınırlamalar belirlemek.
 - En Zayıf Halkayı Tespit Edip Güçlendirmek: Sistemdeki en zayıf noktaları belirlemek ve güçlendirmek.
 - Saldırı Yüzey Alanını Azaltmak: Sistemdeki saldırı noktalarını azaltmak için gereksiz servis ve portları kapatmak.
 - Savunma Derinliği Oluşturmak: Tek bir güvenlik önlemi başarısız olduğunda bile sistemi savunmak için birden fazla savunma katmanı oluşturmak.
 - Basit ve Anlaşılabilir Güvenlik Mekanizması Tasarlamak: Güvenlik mekanizmalarını anlaşılır, etkili ve kullanıcı dostu bir şekilde tasarlamak.

Yazılım Güvenliğini Sağlama Yöntemleri: Sezgisel ve Benzetime Dayalı

- Yazılımdaki hataları azaltmak ve yazılımın güvenliğini artırmak için çeşitli yöntemler mevcuttur. Bunlardan biri sezgisel (heuristic) ve benzetime (simulation) dayalı yöntemlerdir.
 - Sezgisel ve benzetime dayalı yöntemler şunlardır:
 - Statik Analiz Yöntemi (Static Analysis): Yazılım kodunu analiz ederek potansiyel güvenlik açıklarını tespit etmek için kullanılır. Kodun yapısını ve mantığını inceler.
 - Sembolik Uygulama Yöntemi (Symbolic Execution): Programın sembolik bir örneğini oluşturup, farklı giriş değerleri üzerinde sembolik şekilde çalıştırarak güvenlik açıklarını tespit eder.
 - Dinamik Analiz Yöntemi (Dynamic Analysis): Yazılımın çalışma zamanında gerçekleştirilen bir analiz yöntemidir. Yazılım gerçek bir ortamda çalıştırılır ve güvenlik açıkları veya hatalı davranışlar tespit edilmeye çalışılır.
 - Ağ Tarayıcısı: Nmap gibi araçlarla ağ üzerindeki cihaz ve yazılımların özelliklerini tespit eder.
 - Ağ Dinleyicisi: Wireshark gibi araçlarla ağ trafiğini dinleyerek anlık analiz eder veya kaydeder.
 - Ağ Zayıflık Tarayıcısı: OpenVAS gibi araçlarla ağ cihazlarına, yazılımlarına veya servislere özel trafik göndererek zayıflıkları tespit eder.
 - Negatif Test (Negative Testing) Yöntemi: Yazılımın beklenmedik veya hatalı girişlere nasıl tepki verdiğini test etmek için kullanılır.
 - Rastgele Test (Fuzz Testing) Yöntemi: Yazılımı test etmek için rastgele giriş değerleri kullanılan bir yöntemdir.

Yazılım Güvenliğini Sağlama Yöntemleri: Biçimsel Yöntemler

- Biçimsel yöntemler, yazılım güvenliği analizi için matematiksel ve mantıksal temellere dayanan bir yaklaşımdır. Bu yöntemler, yazılım sistemlerinin doğruluğunu ve güvenliğini matematiksel olarak kanıtlamak veya olası hataları tespit etmek için kullanılır.
- Biçimsel yöntemlerin bazıları şunlardır:
 - Biçimsel Program Analizi: Yazılımın matematiksel ve mantıksal analizini kullanarak doğruluğunu ve güvenliğini değerlendirir.
 - Model Doğrulayıcılar: Yazılımın özelliklerini matematiksel modeller kullanarak doğrulayan ve analiz eden araçlar ile tekniklerdir (örn. Z, Alloy, SPARK, Coq, PROMELA gibi formel diller).
 - Mantık Yöntemleri: Mantık temelli formel dil ve yöntemleri kullanarak yazılım güvenliğini analiz etmeyi amaçlar.
 - Doğrulanmış Araç ve Kod Depoları Kullanma: Biçimsel olarak doğrulanmış araçlar ve kod depoları kullanarak güvenli yazılım geliştirmeye odaklanır.
 - Kod Güçlendirme: Biçimsel yöntemler kullanılarak yazılımın güvenliğinin artırılmasına yönelik güçlendirme teknikleridir.
 - İspat Taşıyan Kod: Yazılımın belirli özelliklerini matematiksel ispatlarla desteklenen şekilde kodlamayı amaçlar.

- Bazı güvenlik işlevlerinin sistem tarafında ortak kullanılabilir mekanizmalarla sağlanması, saldırılara karşı dayanıklı ve güvenlik hizmetlerini varsayılan olarak sağlayan çalışma ortamı oluşturulması, yazılımın güvenliğini artıracak önlemler arasındadır.
- Ortak güvenli mimari örüntülerinin kullanılması, yeni nesil yazılım teknolojilerinde güvenliği artırır.
- Yazılım çalışma ortamının güvenliğini sağlayan yöntemlerin bazıları şunlardır:
 - Sanallaştırma Ortamlarının Kullanılması: Bir fiziksel sunucu üzerinde birden fazla sanal makine çalıştırma yöntemidir. Sanal makineler, izole bir ortamda çalışır ve güvenlik açıklarının yayılmasını önler. VMware vSphere, Microsoft Hyper-V, Citrix Hypervisor, Oracle VM VirtualBox, Docker vb. örnek olarak verilebilir.
 - Yazılımların Mikroservis Mimarisiyle Geliştirilmesi.
 - Uygulama Konteyneri (Application Container) kullanımı.

- Uluslararası yazılım güvenliği standartları, yazılım geliştirme sürecinde güvenlik konularını ele alarak yazılımların saldırılara karşı daha dayanıklı ve güvenli bir şekilde çalışmasını sağlamayı amaçlar.
- Bu standartlar, yazılımın yaşam döngüsünün farklı aşamalarında güvenlik prensiplerini uygulamayı ve en iyi güvenlik uygulamalarını teşvik etmeyi hedefler.
- Uluslararası yazılım güvenliği standartları, benzer güvenlik risklerine karşı tüm sektörlerde ve ülkelerde ortak bir dil ve yaklaşım sağlayarak yazılım güvenliğinin geliştirilmesine yardımcı olur.
- Bu durum hem kullanıcıların güvenliğini artırır hem de yazılım tabanlı hizmetlerin ve ürünlerin siber tehditlere karşı daha dirençli olmasını sağlar.

- Uluslararası yazılım güvenliği standartları şunlardır:
 - ISO/IEC 27001
 - ISO/IEC 15408 (Common Criteria)
 - ISO/IEC 27034
 - ISO/IEC 29147
 - ISO/IEC 30111
 - ISO/IEC 25010 (SQuaRE)
 - OWASP Top 10
 - CERT Secure Coding Standards
 - CIS Critical Security Controls
 - NIST SP 800-53

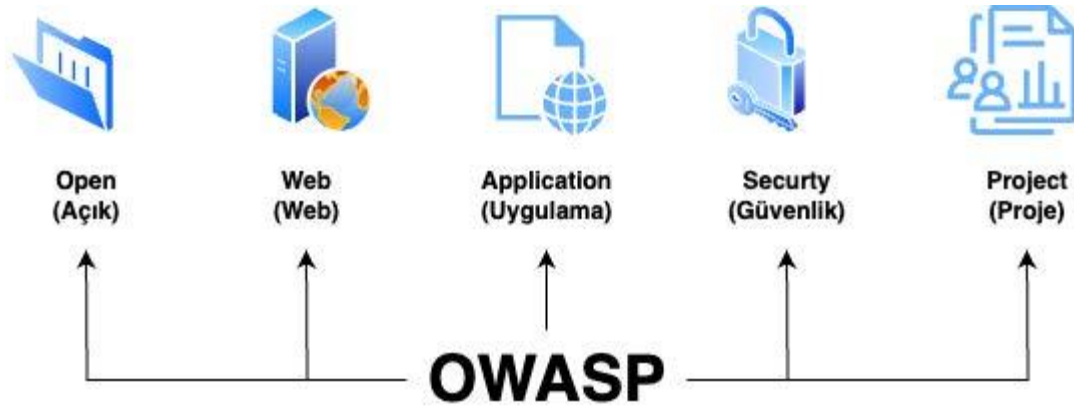


- ISO/IEC 27001: Bilişim güvenliği yönetim sistemlerinin kurulması, uygulanması, izlenmesi, denetlenmesi ve sürekli iyileştirilmesi için gereksinimleri belirten bir standarttır. Yazılım geliştirme sürecini ve uygulamaları kapsayan geniş bir çerçeve sunar. Genellikle ISO 27001 standardı olarak anılır.
- ISO/IEC 15408 [Common Criteria (Ortak Kriterler)]: Bilgi teknolojisi ürünlerinin ve sistemlerinin güvenlik özelliklerini değerlendirmek ve sertifikalandırmak için kullanılan uluslararası bir standarttır. Yazılım, donanım ve sistemler gibi çeşitli bilişim sistemleri bileşenlerinin güvenlik değerlendirmelerini gerçekleştirmek için tasarlanmıştır.

- ISO/IEC 27034: Uygulama güvenliği yönetimini ele alan bir standarttır. Yazılım uygulamalarının tasarımından geliştirilmesine ve test edilmesine kadar olan süreci kapsar ve yazılım güvenliği risklerini yönetmek için rehberlik sağlar.
- ISO/IEC 29147: Güvenlik açıklarının raporlanması için kılavuzlar içerir. Güvenlik açıklıklarının tespit edilmesi, bildirilmesi ve düzeltilmesi sürecini düzenlemeyi hedefler.
- ISO/IEC 30111: Ürünlerdeki güvenlik açıklarının yönetimi ve koordinasyonunu düzenler. Güvenlik açıklıklarının işleme sürecini düzenlemek için kullanılır.
- ISO/IEC 25010 (SQuaRE): Yazılımın ürün kalitesini değerlendirmek için kılavuzlar sunar. Yazılımın işlevselliğini, güvenilirliğini, kullanılabilirliğini, performansını ve diğer kalite özelliklerini ele alan bir çerçevedir.



- OWASP Top 10: En yaygın web uygulaması güvenliği risklerini sıralayan bir proje ve rehber serisi sunar. En kritik web güvenliği risklerini ve bu risklerle nasıl başa çıkılacağını tanımlar.



- CERT Secure Coding Standards: Yazılım geliştiricilere rehberlik sağlamak ve güvenli kodlama uygulamalarını teşvik etmek için oluşturulmuş bir dizi standarttır. Kod yazımından önce ve kod yazımı sırasında dikkate alınması gereken güvenlik ilkelerini açıklar.
- CIS Critical Security Controls: Uygulanması gereken siber güvenlik kontrollerinin listesini sunar. Organizasyonların ve yazılım geliştiricilerin siber saldırılara karşı dirençli sistemler oluşturmak için bu kontrolleri takip etmeleri önerilir.
- NIST SP 800-53: Amerika Birleşik Devletleri Ulusal Standartlar ve Teknoloji Enstitüsü (NIST) tarafından geliştirilen bu rehber, federal bilgi sistemlerinin güvenliğini artırmak için kullanılır. Yazılım güvenliği, genel bilgi sistem güvenliğinin bir parçası olarak ele alınır.



- Bilginin güvenliği için gizlilik, bütünlük ve erişilebilirlik unsurlarının sağlanması hayati öneme sahiptir.

- ISO 27001 Bilgi Güvenliği Yönetim Sistemi (BGYS), kurum ve kuruluşların bilgi güvenliği politikalarını, prosedürlerini ve süreçlerini belirleyip uygulayarak bilgi varlıklarını korumalarını sağlar. Güvenli ağlar oluşturmak için ISO 27001 Bilgi Güvenliği Yönetim Sistemi gibi standartlara uyulmalıdır.

- BGYS, bilgi üzerindeki riskleri ortadan kaldırmayı veya etkilerini azaltmayı temel alan bir yönetsel süreçtir. Bu süreçte Planla-Uygula-Kontrol Et-Önlem Al (PUKÖ) döngüsü benimsenmiştir:

- Planla: BGYS politikası, amaçları, hedefleri ve prosedürleri belirlenir.
 - Uygula: BGYS politikası ve kontrolleri gerçekleştirilir ve işletilir.
 - Kontrol Et: BGYS performansı değerlendirilir ve raporlanır.
 - Önlem Al: Yönetimin gözden geçirme sonuçlarına dayalı olarak düzeltici ve önleyici faaliyetler yapılır.
- ISO 27001 BGYS, kurumun bilgi güvenliği sürecini daha etkin ve güvenilir hâle getirerek rekabet avantajı sağlar.



- ISO 27002, ISO 27000 ailesinin üyesi olan uluslararası bir standarttır ve bilgi güvenliği yönetimi için bilgi güvenliği kontrollerini ve en iyi uygulamaları içerir.
 - ISO 27002 standardı, ISO 27001 standardıyla birlikte kullanılır.
 - ISO 27001'de sadece liste olarak belirtilen güvenlik kontrollerinin nasıl uygulanacağını belirterek kapsamlı bir rehber sunar.
 - 2022 yılında güncellenen ISO 27002 standardındaki kontroller, dört başlık altında doksan üç kontrolden oluşur:
 - Organizasyonel Kontroller (37 Kontrol): Bilgi güvenliğine yönelik politikalar, bilgi güvenliği rolleri ve sorumlulukları, tehdit istihbaratı gibi.
 - Fiziksel Kontroller (14 Kontrol): Fiziksel giriş, temiz masa ve net ekran, kablolama güvenliği gibi.
 - Teknolojik Kontroller (34 Kontrol): Kriptografi kullanımı, veri sızıntısının önlenmesi, günlük kaydı gibi.
 - Kişi Kontrolleri (8 Kontrol): Disiplin süreci, uzaktan çalışma, tarama gibi.

- ISO 27032, ISO 27000 ailesinin üyesi olan uluslararası bir standarttır.
 - ISO 27001 ile birlikte kullanılan bu standart, kurum ve kuruluşların siber güvenliğini iyileştirmek için rehberlik eder.
 - ISO 27032 standardı; bilgi güvenliği, ağ güvenliği, internet güvenliği ve kritik bilgi altyapılarının korunması konularına odaklanır.



Siber Olaylara Müdahale Ekibi (SOME)

Bilişim teknolojilerini yaygın biçimde kullanan kamu ve özel sektör kurumları siber tehditlerle karşı karşıya kalır. Bu tehditler özellikle kritik sistemlere sahip finans, enerji, sağlık, haberleşme, ulaşım vb. sektörleri olumsuz yönde etkiler. Bunun sonucunda itibar ve güven kaybı yaşanabilir. Bu nedenle tüm kamu ve özel sektör kurumları yasal düzenlemeler çerçevesinde gerekli güvenlik önlemlerini almakla yükümlüdür.

Siber olayları yakalamak, olay raporlarını almak, siber olaylara müdahale etmek, siber saldırılara karşılık vermek amacıyla kamu ve kritik altyapıya sahip özel sektör kurumlarında Siber Olaylara Müdahale Ekibi (SOME) kurulması zorunlu hâle gelmiştir.



Siber Olaylara Müdahale Ekibi (SOME)

Ülkemizde, siber güvenlik olaylarına müdahalede ulusal ve uluslararası koordinasyonu sağlamak amacıyla 2014 yılında BTK bünyesinde Ulusal Siber Olaylara Müdahale Merkezi (USOM) kurulmuştur. USOM; siber ortamda olası risk ve tehditlerin belirlenmesi, olası saldırı ve olayların etkilerinin azaltılması, kritik sistemlere yönelik saldırıların önlenmesi, siber olayların paylaşılması, siber tehditlere karşı alarm, uyarı ve duyuru yapılması gibi faaliyetler yürütür. USOM ayrıca kurum ve kuruluşlara, siber olaylara müdahale ekiplerini oluşturmaları konusunda yardımcı olur. Ülkemizdeki en üst düzey SOME, USOM bünyesindedir. USOM altında Kurumsal SOME ve Sektörel SOME adlarıyla kurulmuş iki ana ekip yer alır

Siber Olaylara Müdahale Ekibi (SOME)

Kurumsal SOME: Bakanlıklar, müstakil kamu kurumları ve bilgi işleme sahip diğer kamu kurumları ile koordinasyon hâlinde bulunur.

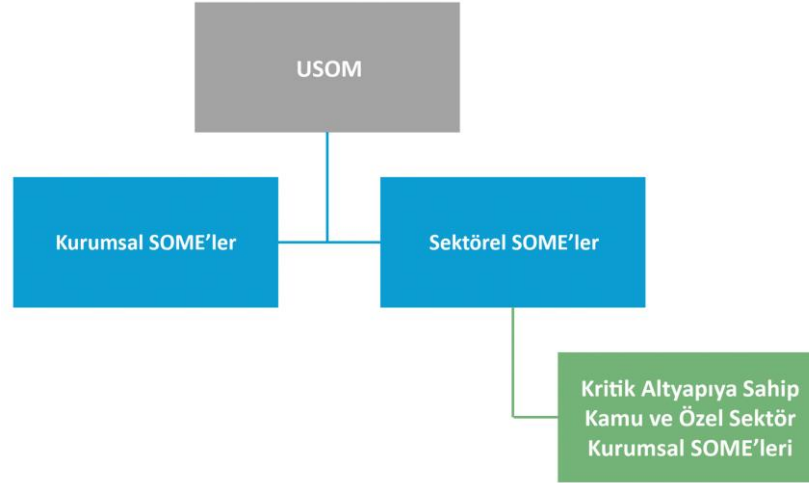
Sektörel SOME: Kritik seviyede iş yapan özel sektör ve kamu kurumları ile koordinasyon hâlinde bulunur.



Siber Olaylara Müdahale Ekibi (SOME)

Kurumsal SOME: Bakanlıklar, müstakil kamu kurumları ve bilgi işleme sahip diğer kamu kurumları ile koordinasyon hâlinde bulunur.

Sektörel SOME: Kritik seviyede iş yapan özel sektör ve kamu kurumları ile koordinasyon hâlinde bulunur.



SOME – NOT

Müstakil bir bilgi işlem birimi barındıran tüm kamu kurum ve kuruluşları ile kritik altyapı işleten özel sektör kuruluşlarında Kurumsal SOME kurulması zorunludur.

Enerji, bankacılık ve finans, ulaştırma, kritik kamu hizmetleri, kritik imalat sanayi, su yöne-timi, kimya üretimi ve elektronik haberleşme konusunda çalışan kurumlar kritik sektörler içinde yer alır. Kritik sektörleri düzenleme ve denetleme sorumluluğu olan kurumlar bünye-sinde Sektörel SOME kurulması zorunludur.



Siber Olaylara Müdahale Ekibi (SOME)

Kurumsal SOME, sorumluluk alanındaki görevlerini yerine getirirken USOM ve varsa bağlı olduğu Sektörel SOME ile iletişim hâlinde olmalıdır. USOM ve SOME'ler siber olay yönetiminin ulusal düzeyde koordinasyon ve iş birliği içinde gerçekleştirilmesinde büyük önem taşır.

Ülkemizdeki bir bankada oluşturulan Kurumsal SOME, USOM ve BDDK / SPK bünyesinde kurulmuş Sektörel SOME ile koordinasyon içinde ve iletişim hâlinde.



Siber Olaylara Müdahale Ekibi (SOME)

Siber olaylara müdahale ekipleri;

- Siber saldırılara karşı önlemler almakla,
- Bilgi güvenliği ile ilgili düzeltici ve onarıcı hizmetleri vermekle,
- Sistemlerde oluşabilecek olağanüstü durumlara karşı log sistemi kurmakla,
- Güncel saldırılar ve süreçleri hakkında bilgi sahibi olmakla,
- Siber olayları raporlamakla,
- Siber saldırılara karşılık vermekle,
- Kurum ve kuruluşların bilgi güvenliğini sağlamakla yükümlüdür.

Siber Olaylara Müdahale Ekibinin Görev ve Sorumlulukları

SOME'lerin görev ve sorumlulukları; siber olay öncesi, siber olay esnası, siber olay sonrası şeklinde belirtilir.



Siber Olay Öncesi

Kurumsal SOME'ler;

- Kurum içi farkındalık çalışmalarının gerçekleştirilmesi,
- Kurumsal bilişim sistemleri sızma testlerinin yapılması / yaptırılması,
- Kayıtların düzenli olarak izlenmesi ve incelenmesi,
- Kayıtlar üzerinde dönemsel analiz ve ilişkilendirme çalışmasının yapılması ve raporlanması,
- Kurumun diğer birimlerle ilişkilerinin düzenlenmesi,
- Siber olay yönetim talimatlarının hazırlanması,
- USOM ve varsa bağlı olduğu Sektörel SOME tarafından önerilen / düzenlenen toplantı ve etkinliklere katılım sağlanması,
- Güvenlik ürünlerinin (saldırı tespit sistemi, güvenlik duvarı vb.) belirlenmesi sürecinde bilgi işleme destek verilmesi,
- Güvenlik ürünlerinin işletimi ile ilgili politikaların bilgi işleme koordineli şekilde belirlenmesi görev ve sorumluluklarını yerine getirir.

Siber Olay Esnası

Kurumsal SOME'ler;

- İşlem adımlarının bilgi işlem birimi, internet servis sağlayıcı, Sektörel SOME, USOM, hukuk müşavirliği, savcılık, kolluk kuvveti ve basın müşavirliği ile birlikte uygulanması,
- Olaya müdahale esnasında bilişim sistemlerine yetkisiz erişim yapılmaması için gerekli tedbirlerin alınması,
- Siber olay bildirim (EK-2) formunun doldurulması,
- Siber olay müdahale akışı içinde suç unsuruna rastlanması hâlinde savcılık, kolluk kuvvetleri vb. makamlara haber verilmesi hem kanuni yükümlülüğün yerine getirilmesi hem de ulusal siber güvenlik kapsamında caydırıcılığın sağlanması görev ve sorumluluklarını yerine getirir.

Siber Olay Esnası

SİBER OLAY BİLDİRİM FORMU															
1. Bildirimi yapan SOME:															
2. Bildirimi yapan personelin Adı Soyadı : Unvan / Birim : Telefon : E-posta :															
3. Olay türü: <table><tbody><tr><td>☐ Servis Dışı Bırakma (DDoS)</td><td>☐ Web Defacement</td></tr><tr><td>☐ Bilgi Sızdırma (Data Leakage)</td><td>☐ Sosyal Mühendislik</td></tr><tr><td>☐ Zararlı Yazılım (Malware)</td><td>☐ Spam</td></tr><tr><td>☐ Dolandırıcılık (Fraud)</td><td>☐ Port Tarama</td></tr><tr><td>☐ Kimlik Taklidi</td><td>☐ Oltalama (Phishing)</td></tr><tr><td>☐ SQL Injection</td><td></td></tr><tr><td>☐ Diğer (Lütfen açıklayınız):</td><td></td></tr></tbody></table>		☐ Servis Dışı Bırakma (DDoS)	☐ Web Defacement	☐ Bilgi Sızdırma (Data Leakage)	☐ Sosyal Mühendislik	☐ Zararlı Yazılım (Malware)	☐ Spam	☐ Dolandırıcılık (Fraud)	☐ Port Tarama	☐ Kimlik Taklidi	☐ Oltalama (Phishing)	☐ SQL Injection		☐ Diğer (Lütfen açıklayınız):	
☐ Servis Dışı Bırakma (DDoS)	☐ Web Defacement														
☐ Bilgi Sızdırma (Data Leakage)	☐ Sosyal Mühendislik														
☐ Zararlı Yazılım (Malware)	☐ Spam														
☐ Dolandırıcılık (Fraud)	☐ Port Tarama														
☐ Kimlik Taklidi	☐ Oltalama (Phishing)														
☐ SQL Injection															
☐ Diğer (Lütfen açıklayınız):															
4. Olay, sistem kesintisine sebep oldu mu? ☐ Evet ☐ Hayır															
5. Olayın tahmini başlangıç zamanı: Tarih: Saat: Olayın tespit edildiği zaman: Tarih: Saat:															
6. Ekleme istedikleriniz:															



Siber Olay Sonrası

Kurumsal SOME'ler;

- Vakit kaybetmeden olaya neden olan zafiyetin belirlenmesi,
- Siber olay ile ilgili bilgilerin Siber olay değerlendirme (EK-3) formuna doldurulması, USOM'a ve varsa bağlı olduğu Sektörel SOME'ye gönderilmesi,
- Olayla ilgili düzeltici / önleyici faaliyetlere ilişkin önerilerin belirlenmesi ve kurum yönetimine sunulması,
- Olay türü, miktarı ve maliyetinin tespit edilmesi,
- Siber olay müdahale raporunun hazırlanması,
- Raporun kurum yönetimi, USOM ve varsa bağlı olduğu Sektörel SOME'ye iletilmesi görev ve sorumluluklarını yerine getirir.

SİBER OLAY DEĞERLENDİRME FORMU	
1. Bildirimi yapan SOME:	
2. Bildirimi yapan personelin Adı Soyadı : Unvan / Birim : Telefon : E-posta :	
3. Olay türü: ☐ Servis Dışı Bırakma (DDoS) ☐ Web Defacement ☐ Bilgi Sızdırma (Data Leakage) ☐ Sosyal Mühendislik ☐ Zararlı Yazılım (Malware) ☐ Spam ☐ Dolandırıcılık (Fraud) ☐ Port Tarama ☐ Kimlik Taklidi ☐ Oltalama (Phishing) ☐ SQL Injection ☐ Diğer (Lütfen açıklayınız):	
4. Olay, sistem kesintisine sebep oldu mu? ☐ Evet ☐ Hayır	
5. Etkilenen sistemler: ☐ Uygulama Sunucusu ☐ Veri Tabanı Sunucusu ☐ DNS ☐ Posta Sunucusu ☐ Web Sunucusu ☐ Dosya Sunucusu ☐ Güvenlik Duvarı ☐ Diğer (Lütfen açıklayınız):	
6. Olayın kısa tanımı:	
7. Olayı bildiren kişi / kurum ve olayın tespit edilme yöntemi: ☐ Kurum dışı bildirim ☐ Kurum çalışanı ☐ Kurumsal SOME çalışanı ☐ Bilgi işlem birimi ☐ Diğer (Lütfen açıklayınız): Olayın tespit edilme yöntemini açıklayınız:	
8. Olayın tahmini başlangıç zamanı: Tarih: Saat:	
Olayın tespit edildiği zaman: Tarih: Saat:	
9. Siber olaylara ait iz kayıtları tespit edildi mi? ☐ Hayır ☐ Evet Kaynak IP : Hedef IP : Port : Diğer :	
10. Alınan karşı önlemleri açıklayınız:	
11. Ekleme istedikleriniz:	

Siber Olaylara Müdahale Ekibinin İç ve Dış Paydaşlarla İletişim Esasları

Kurumsal SOME'nin iç paydaşlarında bilgi işlem birimi ile hukuk ve basın müşavirlikleri yer alır. Kurumsal SOME, kurumun siber güvenliğini yönetmek için iç paydaşlarla birlikte çalışır. Bilgi işlem birimi, bilişim sistemlerinin yönetimini yapmak ve sürekliliğini sağlamak amacıyla faaliyetler gerçekleştirir. Kurumsal SOME'nin bilgi işlem biriminden farklı görevleri bulunur. Bu nedenle Kurumsal SOME, Bilgi İşlem Birimi veya Bilgi Güvenliği / Siber Güvenlik Birimi altında farklı personeller tarafından oluşturulmalıdır.

Kurumsal SOME, siber olay öncesi bilgi işlem sistemine sızma testi çalışması yapar veya yaptırır. İz kayıtlarını takip eder. Siber olay esnasında ise bilgi işlem biriminin yapacağı müdahaleyi yönetir ve bilgi işlem birimindeki ilgili personeli koordine eder.

Kurumsal SOME'nin dış paydaşlarında ise USOM ve Sektörel SOME yer alır. Kurumsal SOME, 7/24 ulaşılabilir durumda olan personelin iletişim bilgilerini Tablo 1.4'teki SOME iletişim formuna (EK-1) doldurur. Bu formu USOM ve varsa bağlı olduğu Sektörel SOME'ye güvenli iletişim sistemi üzerinden iletir.

Kurumsal SOME'ler gerektiğinde USOM'un yanı sıra diğer Kurumsal SOME'lere de bilgi verebilir. USOM tarafından güvenli bir iletişim kanalı oluşturuluncaya kadar yapılacak iletişimde mevcut iletişim kanalları kullanılabilir. SOME'lerin e-posta yoluyla yapacağı iletişimin şifreli olması önerilir.



Siber Olaylara Müdahale Ekibinin İç ve Dış Paydaşlarla İletişim Esasları

SOME İLETİŞİM FORMU					
Kurum Adı:					Tarih:
SOME Takımı 7/24 İletişim Bilgileri		Telefon	Cep telefonu	Faks	Kurumsal e-posta
Hizmet Aldığı ISS					
ISS'ten Aldığı Güvenlik Hizmetleri		DDoS	Diğer:		
Kullanılan Güvenlik Cihazları		IPS	WAF	FW	Diğer:
Kurum IP Adres Aralığı					
SOME Personelinin	Adı Soyadı	Unvanı	Telefonu	Cep telefonu	Kurumsal e-posta
İzlenmesi Talep Edilen Sistemlerin	Alan Adı	IP Adresi	Açıklama		



Dijital Arşivleme: Tanım ve Aşamalar

- Belgelerin tarayıcılar veya optik karakter tanıma (Optical Character Recognition-OCR) teknolojileriyle dijital ortamlara aktarılması ve .jpeg, .gif, .tif, .pdf gibi değişik dosya formatlarında belirli algoritmalara göre saklanması sürecine dijital arşivleme denir.
- Dijital arşivleme; bilişim sistemleri, sunucular, bulut tabanlı depolama alanları gibi dijital arşivleme altyapıları kullanılarak gerçekleştirilir.
- Dijital arşivlemenin aşamaları şunlardır:
 1. Belgelerin Tasnif Edilmesi: Belgelerin belirli kriterlere göre düzenlendiği ve sınıflandırıldığı aşamadır.
 2. Belgelerin Taranması: Fiziksel belgelerin tarayıcılar veya OCR teknolojileri kullanılarak dijital formata dönüştürüldüğü aşamadır.
 3. Görüntü İyileştirme Uygulaması: Tarama sonrası elde edilen dijital görüntülerdeki kalite düşüklüğü veya bozuklukları giderme aşamasıdır.
 4. İndeks Oluşturulması: Dijital arşivdeki belgelere hızlı ve etkili bir şekilde erişmek için indeks oluşturulur.
 5. Aktarma İşlemi: Tarama, görüntü iyileştirme ve indeksleme işlemleri tamamlanan belgelerin dijital arşivleme veri tabanına kaydedilmesi ve dijital arşivleme sürecinin tamamlanması aşamasıdır.
- Görsel anahtar kelimeler: Digital archiving process, document digitization, OCR technology, electronic records management.

- Dijital arşivlemenin avantajları şunlardır:
 - Belgeler sunucular üzerinde saklandığı için fiziksel alan ihtiyacı daha azdır.
 - Belgelere erişim hızlı ve kolaydır.
 - Belgeler dijital olarak saklandığı için fiziksel olarak yıpranmaz.
 - Dijital belgelere çoklu erişimin sağlanması mümkündür.
 - Teknoloji destekli olduğu için sürdürülebilir ve yönetilebilirdir.
 - Dijital arşivdeki belgelere yetkilendirme temelli erişim sağlanabilir.
 - Kurum ve kuruluşların katma değerini artırır.

Dijital arşivlemenin dezavantajları şunlardır:

- Siber saldırılara karşı uygun güvenlik önlemleri alınmazsa güvenlik riskleri ortaya çıkabilir.
- Herhangi bir veri kaybı durumunda veri kurtarma süreci karmaşık olabilir.
- Düzenli olarak teknolojik altyapı yatırımı gerekebilir.

Anahtar Kelimeler

Hafta 2 – Siber Güvenliğe Giriş

Anahtar Kelimeler

Ağ (Network): İki veya daha fazla bilgisayarın kablolu veya kablosuz iletişim araçları üzerinden yazılım ve donanım bileşenleriyle birbirine bağlandığı, bilgi ve sistem kaynaklarının kullanıcılar arasında paylaşıldığı bir haberleşme sistemi.

Ağ Güvenliği: Ağdaki bilgisayarların güvenliğini sağlamak, ağ trafiğini korumak, ağ saldırılarını algılamak ve önlemek, yetkisiz erişimleri engellemek için gerekli teknikleri, araçları ve güvenlik planlamalarını kapsayan kavram.

Ağ Güvenlik Planı: Bilgisayar ağını yetkisiz kullanıcılardan korumak ve sistemin güvenliğini tehlikeye atabilecek olaylara karşı koruma sağlamak için kullanılan teknikleri tanımlayan strateji.

Gizlilik (Confidentiality): Bilginin yetkisiz kişiler tarafından elde edilmesinin engellenmesi, bilgi güvenliğinin üç temel unsurundan biri.

Bütünlük (Integrity): Bilginin yetkisiz kişiler tarafından değiştirilmesinin veya silinmesinin önlenmesi, bilgi güvenliğinin üç temel unsurundan biri.

Erişilebilirlik (Availability): Bilginin yetkili kişiler tarafından belirlenen zaman dilimlerinde sürekli erişilebilir olması durumu, bilgi güvenliğinin üç temel unsurundan biri.



Anahtar Kelimeler

IDS (Intrusion Detection System – Saldırı Tespit Sistemi): Ağdaki tüm trafiği sürekli dinleyerek, saldırı olarak tanımlanan işlemleri tespit eden ve uyarı veren sistem.

IPS (Intrusion Prevention System – Saldırı Önleme Sistemi): Üzerinden geçen trafiği derinlemesine inceleyerek saldırı niteliği taşıyan paketleri tespit eden ve engelleyen sistem.

IDPS (Intrusion Detection and Prevention Systems): IDS ve IPS cihazlarının bir arada kullanıldığı bütünleşik güvenlik sistemleri.

SIEM (Security Information and Event Management – Güvenlik Bilgisi ve Olay Yönetimi): Ağdaki güvenlik cihazlarından gelen tüm logları toplayan, analiz eden ve gerektiğinde uyarı veren bir yazılım sistemi.

Bal Küpü (Honeypot): Saldırgan hakkında bilgi toplamaya yarayan, kötü niyetli davranışları sergileyerek saldırganın dikkatini çeken tuzak sunucu.

Güvenlik Duvarı (Firewall): Ağ ve bilgisayarları yetkisiz erişimlerden koruyan, yazılım veya donanım olarak tanımlanan güvenlik sistemi.

UTM (Unified Threat Management – Birleşik Tehdit Yönetimi): Her türlü tehdidi tek cihazla engelleyebilen birleşik güvenlik sistemi (Firewall, IPS/IDS, web filtreleme vb. özellikler sunar).



Anahtar Kelimeler

NGFW (Next Generation Firewall – Yeni Nesil Güvenlik Duvarı): DLP, IPS, IDS, içerik filtreleme gibi güvenlik sistemlerini tek bir yapıda toplayan, kimlik denetimi yapabilen kapsamlı ve tümleşik cihaz.

WAF (Web Application Firewall – Web Uygulama Güvenlik Duvarı): Karmaşık web trafiğini detaylı inceleyerek anormallikleri filtreleyen ve saldırgan amaçlı olanları engelleyen araç, OSI modelinin 7. katmanında çalışır.

VLAN (Virtual Local Area Network – Sanal Yerel Alan Ağı): Switch cihazına bağlı bilgisayarları mantıksal olarak gruplandırarak trafiği sınırlama ve güvenliği artırma yöntemi.

VPN (Virtual Private Network – Sanal Özel Ağ): Uzak kullanıcıların güvenli bağlantılar kurmasını sağlayan teknoloji.

Hacker: Bilişim sistemlerindeki zafiyetleri tespit edip kullanarak sistemlere yetkisiz ve izinsiz giriş yapan kişiler.

Siyah Şapkalı Hacker: Zarar vermek veya maddi kazanç sağlamak amacıyla sistemlere izinsiz giriş yapan kötü niyetli bilgisayar korsanları.

Beyaz Şapkalı Hacker (Etik Hacker): Bilişim sistemlerinin güvenliğini artırmak, zafiyetleri tespit etmek ve ortadan kaldırmak için izin alarak çalışan iyi niyetli hackerlar.



Anahtar Kelimeler

Gri Şapkalı Hacker: Siyah şapka ve beyaz şapka hackerların arasında bir yerde duran, izinsiz giriş yapabilen ancak zarar verebileceği gibi zafiyeti kuruma bildirebilen hacker türü.

Siber Saldırı Yaşam Döngüsü (Cyber Kill Chain): Siber saldırı gerçekleştirilirken izlenen planlı aşamalar (Keşif, Silahlanma, İletme, Sömürme, Yükleme, Komuta Kontrol, Hedefe Yönelik Eylemler).

Sosyal Mühendislik Saldırıları: İnsanları yanıltarak bilgi toplamak, manipüle etmek veya duygularını istismar etmek amacıyla psikolojik ve sosyal tekniklerin kullanıldığı saldırı türü.

Servis Dışı Bırakma (DoS/DDoS) Saldırıları: Bir sunucunun geçici veya sürekli olarak hizmet dışı bırakılarak hizmet veremez hale getirilmesini hedefleyen saldırı türü.

Kaba Kuvvet Saldırıları (Brute Force Attacks): Bir kullanıcıya ait olası kullanıcı adı ve şifre kombinasyonlarını deneyerek ele geçirmeye yönelik saldırı türü.

Ortadaki Adam (Man-in-the-Middle) Saldırısı: Aynı ağ içinde haberleşen iki bilgisayarın arasına girilerek ağ trafiğinin saldırgan bilgisayar üzerinden gerçekleştirildiği saldırı türü.

SQL Enjeksiyon Saldırıları: Web uygulamalarındaki güvenlik açıkları kullanılarak SQL sorgularına müdahale ederek hedef veri tabanındaki SQL kodlarını değiştirmeye yönelik saldırı türü.



Anahtar Kelimeler

Sıfırıncı Gün (Zero Day) Saldırıları: Güvenlik açığı bulunan yazılımların veya sistemlerin, henüz üreticisi tarafından fark edilmediği ve güvenlik açığının ortadan kaldırılmadığı durumdan yararlanılan siber saldırı.

Zararlı Yazılım (Malware): Kötü niyetli amaçlar için geliştirilen yazılımların genel adı.

Virüs: Bir programa, belgeye veya yürütülebilir dosyaya kendi kopyasını ekleyerek yayılan kötü amaçlı yazılım, kullanıcı etkileşimi ile çalışır.

Solucan (Worm): Bir ağ içindeki bilgisayarlara bulaştığında kendi kendine yayılan zararlı yazılım, kullanıcı etkileşimi gerektirmez.

Fidye Yazılımı (Ransomware): Kullanıcının bilgisayarındaki sistem ve dosyaları şifreleyerek erişimi engelleyen ve fidye talep eden zararlı yazılım.

Keylogger (Tuş Kaydedici): Kullanıcının klavyeden bastığı her tuşu yakalayarak kaydeden ve saldırganlara gönderebilen zararlı yazılım.

Rootkit (Kök Kullanıcı Takımı): Saldırganlara bir sisteme uzaktan erişim ve kontrol izni vermek için kullanılan, işletim sisteminin çekirdeğinde gizlenen zararlı yazılım.

SOME (Siber Olaylara Müdahale Ekibi): Siber olayları yakalamak, raporlamak, müdahale etmek ve siber saldırılara karşılık vermek amacıyla kurulan ekipler.



Anahtar Kelimeler

USOM (Ulusal Siber Olaylara Müdahale Merkezi): Siber güvenlik olaylarına müdahalede ulusal ve uluslararası koordinasyonu sağlamak amacıyla kurulmuş merkez.

Kurumsal SOME: Bakanlıklar, müstakil kamu kurumları ve bilgi işleme sahip diğer kamu kurumları ile koordinasyon halinde bulunan SOME.

Sektörel SOME: Kritik seviyede iş yapan özel sektör ve kamu kurumları ile koordinasyon halinde bulunan SOME.

6698 Sayılı Kişisel Verilerin Korunması Kanunu (KVKK): Kişisel verilerin işlenmesinde temel hak ve özgürlükleri korumayı amaçlayan yasal düzenleme.

ISO 27001 Bilgi Güvenliği Yönetim Sistemi: Kurum ve kuruluşların bilgi güvenliği politikalarını, prosedürlerini, süreçlerini belirlemelerine, uygulamalarına ve sürekli iyileştirmelerine rehberlik eden uluslararası standart.

Dijital Arşivleme: Fiziksel belgelerin tarayıcılar veya OCR teknolojileriyle dijital ortamlara aktarılması ve belirli dosya formatlarında saklanması süreci.

Adli Bilişim (Digital Forensics): Bilişim alanında işlenen suçlarla ilgili dijital ortamlarda bulunan verilerin mahkemede sayısal delil niteliği taşıyacak şekilde elde edilmesi, muhafaza edilmesi, analiz edilmesi ve raporlanması çalışmaları.



Anahtar Kelimeler

OWASP Top 10 (Open Web Application Security Project): Web uygulamalarının en yaygın güvenlik zafiyetlerini ve risklerini belirleyen uluslararası bir proje ve rehber serisi.

Statik Analiz Yöntemi: Yazılım kodunu çalıştırmadan analiz ederek potansiyel güvenlik açıklarını tespit etmek için kullanılan yöntem.

Dinamik Analiz Yöntemi: Yazılımın çalışma zamanında, gerçek bir ortamda çalıştırılarak güvenlik açıklarını veya hatalı davranışları tespit etmeye çalışan analiz yöntemi.

Sanallaştırma Ortamları: Bir fiziksel sunucu üzerinde birden fazla sanal makine çalıştırma yöntemi, yazılım çalışma ortamının izole edilmesini sağlar.



Çalışma Soruları

Hafta 2 – Siber Güvenliğe Giriş

Çalışma Soruları

- Ağ güvenliği kavramını tanımlayarak, kişisel ve kurumsal verilerin ağlar üzerinden aktarılmasının neden saldırganları cezbedtiğini açıklayınız. Ağ güvenliği, ağdaki bilgisayarları koruma, trafiği izleme, saldırıları engelleme ve yetkisiz erişimi önleme tekniklerini kapsar. Kişisel ve kurumsal kıymetli veriler ağlar üzerinden aktarıldığı için saldırganlar bu bilgilere ulaşarak maddi kazanç, itibar kaybı veya hassas veri sızdırma gibi kötü niyetli amaçlarını gerçekleştirmeyi hedefler.
- Siber saldırılara neden olan etkenlerden en az üç tanesini sıralayınız ve her birine kısa bir açıklama yapınız. Ağ cihazlarının eksik veya yanlış yapılandırılan konfigürasyonları, cihazların varsayılan ayarlarının değiştirilmemesi ve TCP/IP protokollerindeki zafiyetler siber saldırılara yol açabilir. Bu etkenler, saldırganların sistemlere sızması veya hizmetleri kesintiye uğratması için kullanabileceği kolay hedefler oluşturur.
- Saldırı Tespit Sistemi (IDS) ve Saldırı Önleme Sistemi (IPS) arasındaki temel farkı açıklayınız. IDS (Saldırı Tespit Sistemi) ağ trafiğini dinleyerek saldırıları tespit eder ve yöneticilere uyarı verir ancak trafiğe müdahale etmez. IPS (Saldırı Önleme Sistemi) ise saldırı niteliğindeki trafiği derinlemesine inceler ve saldırıları aktif olarak engelleyerek ağı koruma altına alır.
- Güvenlik duvarı (Firewall) nedir ve başlıca türleri nelerdir? Güvenlik duvarı, ağı ve bilgisayarları yetkisiz erişimlerden koruyan yazılım veya donanım bazlı bir güvenlik sistemidir. Başlıca türleri, daha çok ev ve küçük ofislerde kullanılan yazılımsal güvenlik duvarları (örn. Windows Defender) ve kurumsal ağlarda tercih edilen donanımsal güvenlik duvarlarıdır.
- ISO 27001 Bilgi Güvenliği Yönetim Sistemi'nin (BGYS) temel amacı ve benimsediği döngü nedir? ISO 27001 BGYS'nin temel amacı, kurum ve kuruluşların bilgi varlıklarını korumak, güvenlik risklerini yönetmek ve bilgi güvenliği politikalarını uygulamak için gereksinimleri belirlemektir. Bu sistem, Planla-Uygula-Kontrol Et-Önlem AI (PUKÖ) döngüsünü benimser.



Çalışma Soruları

- Siber güvenlik uzmanının sahip olması gereken temel özelliklerden ve becerilerden üç tanesini açıklayınız. Siber güvenlik uzmanları, problem çözme yeteneğine ve analitik düşünme becerisine sahip olmalıdır, çünkü karmaşık güvenlik sorunlarını çözmeleri gerekir. Ayrıca, hacker gibi düşünebilen araştırmacı özelliklere sahip olmaları, potansiyel tehditleri önceden tahmin etmelerine yardımcı olur.
- Siber Olaylara Müdahale Ekibi (SOME) nedir ve neden kurulması zorunlu hale gelmiştir? SOME, siber olayları yakalamak, raporlamak, müdahale etmek ve siber saldırılara karşılık vermek amacıyla kurulan ekiplerdir. Özellikle kritik sistemlere sahip kamu ve özel sektör kurumları için yasal düzenlemeler çerçevesinde siber tehditlere karşı önlem almak ve olası itibar/güven kayıplarını engellemek amacıyla zorunlu hale gelmiştir.
- Adli bilişim sürecinde dijital delillerin toplanması ve muhafazasında dikkat edilmesi gereken iki önemli hususu belirtiniz. Dijital delillerin toplanmasında, olay yerinin fotoğraflarının çekilmesi ve bilgisayarların elektrik/ağ bağlantısının kesilmesi önemlidir. Muhafazasında ise, disklerin imajının alınması ve bütünlüğünün bozulmaması için hash fonksiyonuna tabi tutularak özetleme kodlarının elde edilmesi hayati öneme sahiptir.
- Yazılım güvenliği ilkelerinden "Savunma Derinliği Oluşturmak" ve "Saldırı Yüzey Alanını Azaltmak" kavramlarını açıklayınız. Savunma Derinliği, tek bir güvenlik önleminin başarısız olması durumunda bile sistemin savunmasını sürdürmek için birden fazla güvenlik katmanı oluşturmayı ifade eder. Saldırı Yüzey Alanını Azaltmak ise, sistemdeki potansiyel saldırı noktalarını (gereksiz servisleri kapatmak, portları kısıtlamak gibi) minimize etmek anlamına gelir.
- OWASP Top 10 nedir ve amacı nedir? OWASP Top 10, web uygulamalarının en yaygın güvenlik zafiyetlerini ve risklerini sıralayan, uluslararası bir proje ve rehber serisidir. Amacı, yazılım geliştiricilerine ve güvenlik uzmanlarına web uygulamalarını geliştirirken ve sürdürürken göz önünde bulundurmaları gereken en kritik güvenlik sorunlarını vurgulayarak bu zafiyetlerin giderilmesi için öneriler sunmaktır.



Deneme Soruları

Hafta 2 – Siber Güvenliğe Giriş

Çalışma Soruları

1. Bilgi güvenliğinin üç temel unsuru olan gizlilik, bütünlük ve erişilebilirliği (CIA Üçlüsü) detaylı olarak açıklayınız. Bu unsurlardan birinin ihlal edildiği bir siber saldırı senaryosu oluşturarak, ihlalin olası sonuçlarını ve bu ihlali önlemek için alınabilecek ağ güvenliği tedbirlerini tartışınız.
2. Bir kurum için kapsamlı bir ağ güvenlik planı oluşturulurken hangi adımların izlenmesi gerektiğini madde madde açıklayınız. Her bir adımın neden önemli olduğunu ve bu adımlar kapsamında hangi tekniklerin veya araçların kullanılabileceğini detaylandırınız.
3. IDS (Saldırı Tespit Sistemi), IPS (Saldırı Önleme Sistemi) ve Bal Küpü (Honeypot) teknolojilerini karşılaştırınız. Her birinin siber savunma stratejilerindeki rolünü, çalışma prensiplerini ve birbirlerini nasıl tamamladıklarını teknik detaylarıyla açıklayınız.
4. Siber güvenlik uzmanının görev ve sorumluluklarını siber olay öncesi, esnası ve sonrası süreçleri bağlamında değerlendiriniz. Bir uzmanın etik ilkeler çerçevesinde hareket etmesinin önemi ve yasal düzenlemelere uyumun siber güvenlik operasyonlarındaki rolü hakkında bir analiz sununuz.
5. Yazılım güvenliği ilkeleri ve uluslararası yazılım güvenliği standartları, güvenli yazılım geliştirme yaşam döngüsünde nasıl entegre edilir? Yazılım güvenlik açıklarını tespit etme ve giderme yöntemlerinden (sezgisel, benzetime dayalı ve biçimsel yöntemler) örnekler vererek, her bir yöntemin avantaj ve dezavantajlarını teknik açıdan açıklayınız.

ÖZET



Süleyman **EZDEMİR**

suleyman.ezdemir@giresun.edu.tr

